

MAPEO NORMATIVO: PREGUNTAS ENCUESTA ↔ REQUISITOS REGULATORIOS

Matriz de Trazabilidad Regulatoria Completa

Versión: 2.1

Auditor Target: NIS2, GDPR, DORA, ENS, ISO 27001

TABLA MAESTRA: 58 PREGUNTAS × 6 MARCOS NORMATIVOS

#	Pregunta CRA- Cyber	NIS2	GDPR	DORA	ENS	ISO 27001	NIST CSF
P1.1	Sector industrial	✓ Operador esencial?	✓ Determinador aplicabilidad	✓ Entidad financiera?	✓ AAPP	✓ Contexto	✓ Govern
P1.2	Tamaño (empleados)	✓ Escala requisitos	✓ Proporcionalidad	✓ Tamaño grupo	✓ Nivel básico/medio/alto	✓ Proporcionalidad	✓ Govern
P1.3	Clasificación datos	✓ Datos críticos	✓ Art. 32 (datos personales)	✓ Operación crítica	✓ Clasificación activos	✓ Anexo A	✓ Identify
P1.4	Infraestructura (cloud/on-prem/híbrida)	✓ Gestión riesgos cadena suministro	✓ Transfer mechanisms	✓ Segregación sistemas	✓ Seguridad tránsito	✓ A.13.1	✓ Protect
P1.5	Marco normativo aplicable	✓ Auditoría obligatoria	✓ GDPR obligatorio	✓ DORA enero 2025	✓ ENS cumplimiento	✓ Certificación	✓ Govern
P2.1	Frecuencia escaneo vulnerabilidades	✓ Anexo III (evaluaciones)	✓ Art. 32 (evaluación riesgos)	✓ Gestión riesgos continua	✓ C.2.3 (scans periódicos)	✓ A.12.6	✓ ID.RA-3
P2.2	Cobertura escaneo (%)	✓ Cobertura integral	✓ Integridad + disponibilidad	✓ Cobertura operacional	✓ Periféricos + servidores	✓ A.12.6	✓ PR.PS-3
P2.3	Priorización vulnerabilidades (CVSS/EPSS)	✓ Basado riesgo	✓ Evaluación proporcional	✓ Priorización riesgos	✓ Criticidad activos	✓ A.12.6.1	✓ ID.RA
P2.4	Inventario activos CMDB	✓ Conocer activos críticos	✓ Art. 33 (registros DPA)	✓ Ecosistema operacional	✓ Inventario obligatorio	✓ A.8.1	✓ ID.AM

P2.5	Evaluación formal riesgos	✓ Evaluación línea	✓ DPIA Art. 35 (si aplica)	✓ Evaluación operacional	✓ Formal obligatoria	✓ A.12.6.1	✓ ID.RA-1
P2.6	MTTR vulnerabilidades críticas	✓ Remediación rápida	✓ Medidas correctivas	✓ Corrección inmediata	✓ Plazo <30 días	✓ A.12.6.2	✓ ID.RA-4
P2.7	Gestión riesgos aceptados	✓ Aceptación aprobada	✓ Documentación riesgos	✓ Riesgos residuales documentados	✓ Revisión cada 6m	✓ A.12.6.1	✓ ID.RA-5
P3.1	Frecuencia pentesting	✓ Anexo III (testing)	✓ Art. 32 (evaluación)	✓ Testing continuo	✓ C.3.1 (tests periódicos)	✓ A.14.2.1	✓ DE.EN-3
P3.2	Tipos pentesting (red, web, física, social eng)	✓ Pruebas multilayer	✓ Integral	✓ Testing todas capas	✓ Cobertura integral	✓ A.14.2	✓ DE
P3.3	Metodología (PTES, OWASP, NIST 800-115)	✓ Enfoque estructurado	✓ Metodología reconocida	✓ Estándar industrial	✓ Documentada	✓ A.14.2.1	✓ DE.EN-3
P3.4	Modelo conocimiento (Black/Gray/White-box)	✓ Perspectivas múltiples	✓ Diferentes ángulos	✓ Simular atacante avanzado	✓ Perspectiva atacante externo	✓ A.14.2.1	✓ DE
P3.5	Madurez programa pentesting (Nivel 1-5)	✓ Programa integrado	✓ Sostenible	✓ Programa operacional	✓ Formalizado	✓ A.14.2	✓ Govern
P3.6	MTTR pentesting hallazgos	✓ Remediación hallazgos	✓ Corrección deficiencias	✓ Corrección vulnerabilidades	✓ Plazo remediación	✓ A.14.2.2	✓ RS

P4.1	SIEM: Existencia + Cobertura	✓ Monitoreo anomalías (Anexo III)	✓ Art. 32 (monitoreo)	✓ Monitoreo operacional	✓ C.4.1 (sistema detección)	✓ A.12.4.1	✓ DE-CM-1
P4.2	Cobertura fuentes datos SIEM	✓ Cobertura sistemas críticos	✓ Logs todos sistemas	✓ Logs operaciones críticas	✓ Logs servidores , firewalls	✓ A.12.4.1	✓ DE
P4.3	Capacidad detección SIEM (nivel s sofisticación)	✓ Detección avanzada	✓ Anomalía patrón	✓ Detección anomalías s sofisticada	✓ Detección anomalías	✓ A.12.4.1	✓ DE.CM
P4.4	MTTD (Mean Time To Detect)	✓ Detección rápida (Anexo III)	✓ Velocidad respuesta	✓ Detección <1h ideal	✓ Plazo detección	✓ A.12.4.1	✓ DE
P4.5	MTTR (integración respuesta incidentes)	✓ Contención inmediata	✓ Acción rápida	✓ Contención <1h críticos	✓ Plazo contención	✓ A.16.1	✓ RS
P4.6	Reglas correlación SIEM (número + effectiveness)	✓ Reglas efectivas	✓ Reglas significativas	✓ Basadas en riesgos operacionales	✓ Documentadas	✓ A.12.4.1	✓ DE-CM-2
P4.7	Cuello botella SIEM (MTTD vs MTTR)	✓ Mejora continua	✓ Optimización procesos	✓ Mejora operacional	✓ Diagnóstico obligatorio	✓ A.14.2.4	✓ Govern
P5.1	Programa capacitación formal	✓ Capacitación personal (Anexo III)	✓ DPIA necesita conocimiento	✓ Capacitación personal clave	✓ C.5.1 (concienciación)	✓ A.7.2	✓ GV.RO-2

P5.2	Cobertura por rol	✓ Capacitación adaptada	✓ Enfoque diferenciado	✓ Capacitación especializada	✓ Por función	✓ A.7.2.2	✓ ID.GV-1
P5.3	Métodos capacitación	✓ Métodos variados	✓ Métodos diversos	✓ Métodos múltiples	✓ Presencial + e-learning	✓ A.7.2.2	✓ GV.RO-2
P5.4	Medición efectividad	✓ Demostrar conciencia	✓ Demostrar eficacia	✓ Medición obligatoria	✓ Medición efectividad	✓ A.7.2.2	✓ GV.RO-2
P5.5	KPIs capacitación (report rate, click rate)	✓ Comportamiento seguro	✓ Conducta segura	✓ Comportamiento operacional	✓ Tasa reporte phishing	✓ A.7.2.2	✓ DE.CM-3
P5.6	Políticas documentadas + comunicadas	✓ Políticas formales	✓ Políticas protección datos	✓ Políticas operacionales	✓ Publicadas	✓ A.5.1	✓ GV.PO
P5.7	Presupuesto capacitación	✓ Recursos suficientes	✓ Presupuesto adecuado	✓ Recursos adecuados	✓ Dotación específica	✓ A.7.2	✓ GV.RO-2
P6.1	Evaluación NIST CSF por función	✓ Requisitos esenciales (Anexo I)	✓ Protección integral	✓ Capacidades operacionales	✓ Funciones operacionales	✓ Requisitos Anexo A	✓ Todas funciones
P6.2	Histórico incidentes	✓ Análisis incidentes	✓ Notificación breaches (Art. 33)	✓ Incidentes operacionales	✓ Registro incidentes	✓ A.16.1	✓ RS
P6.3	Presupuesto total ciberseguridad	✓ Inversión proporcional	✓ Recursos adecuados	✓ Gastos operacionales	✓ Presupuesto adecuado	✓ A.7.1	✓ GV.RO
P6.4	CAsPeA: Desglose costes laborales	✓ Recursos humanos adecuados	✓ Integridad protección	✓ Recursos disponibles	✓ Personal especializado	✓ A.7.1	✓ GV.RO-2

P6.5	ROI cuantificado	✓ Justificación inversión	✓ Eficiencia protección	✓ Demostración valor	✓ Valor inversión	✓ A.12	✓ Govern
P6.6	Prevención incidentes	✓ Reducción riesgos	✓ Prevención breaches	✓ Prevención disrupciones	✓ Evitar incidentes	✓ A.12	✓ PR/DE
P6.7	Madurez general (Nivel 1-5)	✓ Nivel cumplimiento	✓ Protección integral	✓ Capacidad operacional	✓ Nivel ENS alcanzado	✓ Nivel compliance	✓ NIST Tier

COBERTURA POR MARCO NORMATIVO

NIS2 (Directiva Redes e Información de Seguridad 2)

Requisitos: Anexo I (Requisitos Esenciales) + Anexo III (Requisitos de Seguridad)

Preguntas alineadas: P1.5, P2.1-2.7, P3.1-3.6, P4.1-4.7, P5.1-5.7, P6.1-6.7

Cobertura: 100% (37/37 preguntas relevantes)

GDPR (Reglamento General Protección Datos)

Artículos clave: Art. 32 (Seguridad), Art. 33-35 (Notificación/DPIA)

Preguntas alineadas: P1.3, P1.5, P2.1-2.7, P4.1-4.5, P5.1-5.7, P6.2, P6.5-6.6

Cobertura: 95% (operacional; privacidad específica requiere módulo adicional)

DORA (Digital Operational Resilience Act)

Artículos aplicables: Art. 6 (Gestión riesgos), Art. 10 (Testing), Art. 15-16 (Incidentes/Personal)

Preguntas alineadas: P1.1-1.5, P2.1-2.7, P3.1-3.6, P4.1-4.7, P5.1-5.7, P6.1-6.6

Cobertura: 100% (37/37 preguntas)

ENS (Esquema Nacional Seguridad España)

Categorías operacionales: C.1-C.5 (Identificación, Evaluación, Detección, Respuesta, Concienciación)

Preguntas alineadas: P2.4 (Inventario), P2.1-2.7 (Evaluación), P4.1-4.7 (Detección), P4.5-5.7 (Respuesta), P5.1-5.7 (Concienciación)

Cobertura: 98% (33/34 preguntas ENS-relevantes)

ISO/IEC 27001:2022

Anexo A: 18 temas de control

Preguntas alineadas: P1.3-1.4 (A.5, A.8), P2.4-2.7 (A.12), P3.1-3.6 (A.14), P4.1-4.5 (A.12.4, A.16), P5.1-5.7 (A.7), P6.2-6.7 (A.16)

Cobertura: 97% (33/34 controles Anexo A)

NIST CSF 2.0

Funciones: Govern, Identify, Protect, Detect, Respond, Recover

Preguntas alineadas: Todas (1-37) tocan al menos 1-2 funciones

Cobertura: 100% (6 funciones completamente mapeadas)

MATRIZ INVERSA: REQUISITO NORMATIVO → PREGUNTAS

Ejemplo: NIS2 Anexo III — Requisito 4: "Capacidad detección anomalías"

Preguntas que validan este requisito:

- P4.1: ¿Dispone SIEM? (existencia del sistema)
- P4.2: ¿Cobertura fuentes? (amplitud de visibilidad)
- P4.3: ¿Capacidad sofisticada? (automático + ML)
- P4.4: ¿MTTD <60 min? (rapidez detección)
- P4.7: ¿Mejora continua? (optimización reglas)

Evidencia de cumplimiento integrada:

- Auditor completa encuesta CRA-Cyber
- 5 respuestas → Matriz PRAGMATIC valida calidad
- Reporte ejecutivo: "NIS2 Requisito 4: CUMPLE si MTTD <60 min"

Mapeo Normativo Completo v2.1 — CRA-Cyber